📋 Lab 4 – MedGlobal Health
ISO 27001 Bilgi Güvenliği Yönetim Sistemi (BGYS) Denetimi

Senaryo

Bir bilgi sistemleri denetçisi olarak MedGlobal Health şirketinin Bilgi Güvenliği Yönetim Sistemi (BGYS) denetimini gerçekleştirmek üzere görevlendirildiniz.
MedGlobal Health;

- 7 ülkede faaliyet gösteren
- 4.500 çalışanı bulunan
- Sağlık teknolojileri geliştiren
- Bulut tabanlı hasta yönetim sistemleri işleten
- ISO 27001 sertifikasına sahip olduğunu iddia eden

uluslararası bir sağlık teknolojileri şirketidir.
Şirket yönetimi aşağıdaki güvenceyi vermektedir:

- Bilgi güvenliği politikaları günceldir.
- Risk yönetim süreçleri düzenli işletilmektedir.
- Varlık envanteri eksiksizdir.
- Erişim yönetimi süreçleri olgun seviyededir.
- Tedarikçiler düzenli denetlenmektedir.
- Güvenlik olayları etkin şekilde yönetilmektedir.
- İş sürekliliği planları günceldir.
- Çalışan farkındalık eğitimleri tamamlanmıştır.
- Kritik sistemler için riskler kontrol altındadır.
- ISO 27001 gereksinimlerinin tamamı karşılanmaktadır.

Yönetim ekibine göre şirket ISO 27001 açısından oldukça olgun bir yapıya sahiptir ve herhangi önemli bir eksiklik bulunmamaktadır.
Ancak denetim ekibi olarak yalnızca beyanlara güvenmek yerine kanıt toplamanız ve kontrolleri doğrulamanız beklenmektedir.
Bu amaçla şirket size aşağıdaki dokümanları inceleme yetkisi vermiştir.

Şirket Bilgileri
Şirket: MedGlobal Health
Sektör: Sağlık Teknolojileri
Çalışan Sayısı: 4.500
Ülkeler: 7
AWS: Evet
Azure: Evet
Hasta Verisi İşliyor: Evet
ISO 27001 Sertifikası: Evet
Son Sertifikasyon Tarihi: 2023
Bir sonraki gözetim denetimi: 3 ay sonra

Yönetimin Beyanları
CEO:
Bilgi güvenliği bizim için en önemli konulardan biridir.

CISO:
ISO 27001 gereksinimlerinin tamamını karşılıyoruz.

IT Direktörü:
Tüm sistemlerimiz envanter altında.

İK Direktörü:
Ayrılan çalışanların erişimleri aynı gün kaldırılır.

Operasyon Direktörü:
İş sürekliliği planlarımız düzenli test edilmektedir.

Denetim Kapsamı
Denetim aşağıdaki alanları kapsamaktadır:

Clause 4
Organization Context

İncelenecek Dokümanlar
ISMS Scope.pdf
İçerik:
Kapsam:
"Corporate Office"
Ancak:

- AWS ortamı kapsam dışında
- Azure ortamı kapsam dışında
- Hasta verileri kapsam dışında

şeklinde görünmektedir.

Interested Parties.xlsx
Liste:

- Müşteriler
- Çalışanlar

Eksik:

- Regülatörler
- Sağlık Bakanlığı
- KVKK
- GDPR

Clause 5 – Leadership
Information Security Policy
Version:
1.0
Son Güncelleme:
Mart 2022
Yönetim Onayı:

Bulunamadı
Doküman Sahibi:
Belirtilmemiş

ISMS Objectives

Hedef	Ölçüm
Güvenliği artırmak	Yok
Olayları azaltmak	Yok
Riskleri azaltmak	Yok

KPI yok.
Target yok.
Owner yok.

Clause 6 – Planning
Risk Assessment Methodology
Doküman:
Risk_Methodology.docx
Son Güncelleme:
2021

Risk Register.xlsx
Toplam Risk:
18

Örnek:

Risk	Son Güncelleme
Ransomware	2023
Cloud Misconfiguration	2022
Privileged Access Abuse	2021
Third Party Breach	2022

Aşağıdaki riskler bulunmamaktadır:

- MFA Failure
- AI Usage
- Azure Risks
- SaaS Risks
- Supply Chain Attacks

Clause 7 – Support
Security Awareness
Çalışan:
4500
Eğitim Tamamlayan:
2748
Tamamlamayan:
1752

Security Awareness Test
Phishing Simulation
Tıklama Oranı:
27%

Yeniden Eğitim:
Bulunmuyor

Clause 8 – Operation
Asset Inventory.xlsx
Toplam Varlık:
127

IT Operasyon Bilgisi:
- 320 Sunucu
- 1500 Laptop
- 412 Mobil Cihaz
- AWS
- Azure

Access Review
Dosya:
Access_Review_Q1_2024.xlsx
Denetim Tarihi:
2026

Son gözden geçirme:
2 yıl önce

Joiner Mover Leaver

Kullanıcı	Ayrılış Tarihi	Durum
John Smith	2025	Active
Sarah White	2026	Active
Alex Brown	2025	Active

Vulnerability Management
Son Tarama:
14 ay önce

Critical Bulgu:
127
Open

High Bulgu:
394
Open

Annex A 5.9 Asset Inventory
İnceleme:
Asset Inventory
Beklenen:
Tüm varlıklar kayıt altında olmalı.

Annex A 5.15 Access Control
İnceleme:
AD Groups
Access Review
JML

Örnek:
Domain Admins
Üye Sayısı:
19

İş Gereksinimi Belgesi:
Yok

Annex A 5.16 Identity Management
İnceleme:
IAM Policy

Servis Hesapları:
94

Owner bilgisi olmayan:
27

Password Rotation:
Yok

Annex A 5.23 Cloud Security
AWS
Azure

Bulut güvenlik standardı:
Yok

Cloud Risk Assessment:
Yok

Annex A 5.19 Supplier Security
Tedarikçi:
63

Risk değerlendirmesi yapılan:
14

Security Clause bulunan:
18

Penetrasyon Testi Talep Edilen:
3

Annex A 5.24 Incident Management
Security_Incidents.xlsx

Kayıtlı Olay:
3

SOC Dashboard:
- 14 Malware
- 7 Phishing
- 3 Brute Force

Incident Classification:
Yok

Root Cause Analysis:
Yok

Lessons Learned:
Yok

Annex A 5.30 ICT Readiness
BCP Plan

Son Güncelleme:
Temmuz 2022

DR Test:
Yok

Tabletop Exercise:
Yok

RTO:
Var

RPO:
Yok

Clause 9 – Performance Evaluation
Internal Audit
Son İç Denetim:
2023

Aksiyonların Durumu:
Takip edilmiyor

Management Review
Son Toplantı:
2023

Katılımcılar:
Belirtilmemiş

Aksiyonlar:
Yok

Kararlar:
Yok

Clause 10 – Improvement
Corrective Actions
Bulgu Sayısı:
22

Kapatılan:
4

Açık:
18

Bazıları:
18 aydır açık.

Öğrenciden Beklenenler
Öğrenci aşağıdakileri hazırlamalıdır:
Yönetici Özeti
ISMS Olgunluk Değerlendirmesi
ISO 27001 Clause Bazlı Bulgular
Annex A Kontrol Bazlı Bulgular
Risk Seviyesi

- Critical
- High
- Medium
- Low

Root Cause Analysis
Yönetim Sunumu
Sertifika Devam Eder mi?
Gözetim Denetiminde Major / Minor Nonconformity Analizi